

ISO 27001:2022 Comprehensive Gap Assessment Checklist

By Chinmay Kulkarni | Vardhishnu Technologies

Helping businesses stay secure, compliant, and audit-ready.

ISO 27001:2022 Comprehensive Gap Assessment Checklist

Purpose: To assess your organization's readiness for ISO 27001:2022 certification by identifying areas of compliance and gaps within your ISMS.

1. Context of the Organization (Clause 4)

- **Understanding the Organization and Its Context (4.1):**
 - Have internal and external issues relevant to the organization's purpose and that affect its ability to achieve the intended outcomes of the ISMS been determined?
 - Are these issues reviewed and updated regularly?
- **Understanding the Needs and Expectations of Interested Parties (4.2):**
 - Have interested parties relevant to the ISMS been identified?
 - Are their requirements regarding information security documented?
- **Determining the Scope of the ISMS (4.3):**
 - Is the scope of the ISMS defined, taking into account external and internal issues, and the requirements of interested parties?
 - Are the boundaries and applicability of the ISMS documented?
- **Information Security Management System (4.4):**
 - Is the ISMS established, implemented, maintained, and continually improved in accordance with the requirements of the standard?

2. Leadership (Clause 5)

- **Leadership and Commitment (5.1):**
 - Does top management demonstrate leadership and commitment with respect to the ISMS?
 - Are information security policies and objectives established and compatible with the strategic direction of the organization?
- **Policy (5.2):**
 - Is there an information security policy that is appropriate, includes information security objectives, and is communicated within the organization?
- **Organizational Roles, Responsibilities, and Authorities (5.3):**
 - Are roles and responsibilities for information security assigned and communicated?
 - Does top management ensure that responsibilities and authorities are assigned for ensuring the ISMS conforms to the standard?

3. Planning (Clause 6)

- **Actions to Address Risks and Opportunities (6.1):**
 - Has the organization determined risks and opportunities that need to be addressed to ensure the ISMS can achieve its intended outcomes?
 - Are plans in place to address these risks and opportunities?
- **Information Security Risk Assessment (6.1.2):**
 - Is there an established risk assessment process that identifies, analyzes, and evaluates information security risks?
 - Are risk assessments performed at planned intervals or when significant changes are proposed?
- **Information Security Risk Treatment (6.1.3):**
 - Are risk treatment options determined and implemented to manage the identified risks?
 - Is a Statement of Applicability (SoA) prepared, detailing the controls selected and the reasons for their selection?

- **Information Security Objectives and Planning to Achieve Them (6.2):**

- Are measurable information security objectives established?
 - Are plans in place to achieve these objectives, including what will be done, resources required, responsibilities, timelines, and evaluation methods?
-

4. Support (Clause 7)

- **Resources (7.1):**

- Are necessary resources determined and provided for the establishment, implementation, maintenance, and continual improvement of the ISMS?

- **Competence (7.2):**

- Are persons performing work under the organization's control competent based on appropriate education, training, or experience?
- Is competence evaluated and documented?

- **Awareness (7.3):**

- Are employees aware of the information security policy, their contribution to the effectiveness of the ISMS, and the implications of not conforming to the ISMS requirements?

- **Communication (7.4):**

- Are internal and external communications relevant to the ISMS determined, including what to communicate, when, with whom, and how?

- **Documented Information (7.5):**

- Is documented information required by the ISMS and the standard controlled, including creation, updating, and control of documents?
-

5. Operation (Clause 8)

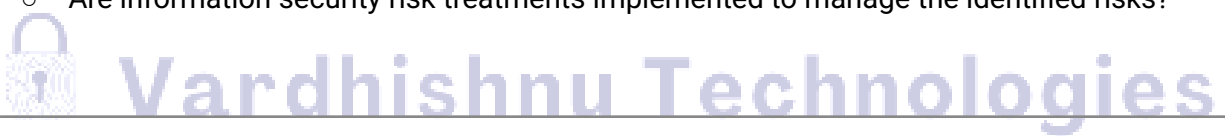
- **Operational Planning and Control (8.1):**

- Are processes needed to meet ISMS requirements planned, implemented, and controlled?
- Are criteria for these processes established, and are controls implemented in accordance with the criteria?

- **Information Security Risk Assessment (8.2):**

- Are information security risk assessments conducted at planned intervals and when significant changes are proposed?

- **Information Security Risk Treatment (8.3):**

- Are information security risk treatments implemented to manage the identified risks?
- 

6. Performance Evaluation (Clause 9)

- **Monitoring, Measurement, Analysis, and Evaluation (9.1):**

- Are information security performance and the effectiveness of the ISMS monitored, measured, analyzed, and evaluated?
- Are results documented and communicated to relevant stakeholders?

- **Internal Audit (9.2):**

- Are internal audits conducted at planned intervals to provide information on whether the ISMS conforms to the organization's requirements and the standard?
- Are audit results reported to relevant management?

- **Management Review (9.3):**

- Does top management review the organization's ISMS at planned intervals to ensure its continuing suitability, adequacy, and effectiveness?
- Are decisions and actions related to continual improvement opportunities and any need for changes to the ISMS documented?

7. Improvement (Clause 10)

- **Nonconformity and Corrective Action (10.1):**
 - When a nonconformity occurs, is it reacted to, and is a corrective action taken to eliminate the cause?
 - Are corrective actions appropriate to the effects of the nonconformities encountered?
 - **Continual Improvement (10.2):**
 - Is the ISMS continually improved to ensure its suitability, adequacy, and effectiveness?
-

8. Annex A Controls (Reference Control Objectives and Controls)

ISO 27001:2022 introduces 93 controls grouped into four themes: Organizational, People, Physical, and Technological. Below is a sample of key controls:

- **Organizational Controls:**
 - Policies for information security
 - Information security roles and responsibilities
 - Threat intelligence
 - Information security in project management
- **People Controls:**
 - Screening
 - Terms and conditions of employment
 - Awareness, education, and training
 - Disciplinary process
- **Physical Controls:**
 - Physical security perimeter
 - Physical entry controls

- Protection against physical and environmental threats
- Secure disposal or re-use of equipment

- **Technological Controls:**

- User endpoint devices
- Access control
- Cryptographic controls
- Information transfer

Note: For a complete list of all 93 controls, refer to Annex A of the ISO 27001:2022 standard.

How to Use This Checklist:

1. **Review each item** and assess your organization's current compliance status.
2. **Document evidence** supporting compliance or identify gaps where improvements are needed.
3. **Develop an action plan** to address identified gaps, assigning responsibilities and timelines.
4. **Monitor progress** and update the checklist regularly to reflect changes and improvements.

Implementing ISO 27001:2022 is a significant step towards enhancing your organization's information security posture. Regularly using this checklist.